Usuários e permissões:

Papel / O que pode fazer
Leitor: pode consultar catálogo, os próprios dados, empréstimos e penalidades
Bibliotecário: administra usuários, livros e operações

Ficam os papéis que já foram definidos, sem adição de admin.

O Bibliotecário é o administrador do sistema. Não é necessário criar is_admin, ou estruturar para várias bibliotecas. O primeiro bibliotecário é criado na mão.

O cadastro de leitores será feito pelo bibliotecário, com o próprio leitor colocando sua senha

O cadastro não altera a sessão de quem está atendendo.

Login e senhas

Usar Argon2id pelo pwdlib, com a configuração padrão da biblioteca. Não tem necessidade de definir no braço a memória, iterações ou o paralelismo. Só guarda o hash em pessoa.senha_hash.

Senhas, hashes e tokens NÃO devem aparecer na API ou nos logs. As credenciais de configuração ficam no .env, fora do repo. O login deve ser feito com login/senha, JWT válido por até 15 minutos. As operações essenciais são:

- Login: verifica as credenciais e emite o token.
- Consultar usuário atual: retorna a identificação e o perfil
- Logout: deve tirar o token do front. Guardar o token só em memória. Quando expirar ou recarregar a página, o usuário precisa fazer login novamente.
- Não é necessário criar tabela de sessão ou refresh token. Sai da pagina -> token removido

Opcional:
- Recuperação de senha (por email, sms, etc)

Proteção das rotas

Criar duas verificações reutilizáveis com o FastAPI:

- Usuário autenticado: valida o JWT e consulta se a conta está ativa
- Bibliotecário: além da autenticação, exige o perfil de bibliotecário.

- O leitor acessa só os próprios registros.
- O servidor busca o id pelo token, não pelo id informado pelo client.
- Qualquer operação de cadastro, mudança ou gestão deve exigir perfil de bibliotecário.
- Penalidade ainda permite login, só nega empréstimo

Testes e documentação:

Cenários relevantes:

- Senha guardada como hash e login válido funcionando
- Senha incorreta ou token expirado rejeitado
- Usuário sem login impedido de acessar rotas restritas
- Leitor impedido de acessar dados de outro leitor ou funções administrativas
- Bibliotecário conseguindo realizar as operações permitidas.

Requisitos gerados:

[ ] SEC01 — Perfis e cadastro: O sistema terá os papéis LEITOR e BIBLIOTECARIO, para uma única biblioteca. O Leitor consulta catálogo, próprios dados, empréstimos e penalidades. O Bibliotecário administra usuários, livros e operações, incluindo a criação de outros bibliotecários. O primeiro será criado manualmente. O cadastro comum deve definir LEITOR no servidor, sem permitir que o cliente escolha permissões. Cadastrar alguém não altera a sessão do operador.

[ ] SEC02 — Senhas e credenciais: Armazenar somente o hash da senha em pessoa.senha_hash, usando Argon2id pelo pwdlib, com configuração padrão e salt gerado pela biblioteca. A senha será definida pelo próprio usuário, em campo mascarado. Senhas e hashes não devem aparecer nas respostas da API ou nos logs. Credenciais do banco e chave de assinatura do JWT ficam no .env, ignorado pelo Git; o .env.example contém apenas exemplos fictícios.

[ ] SEC03 — Autenticação e sessão: O login será por e-mail e senha, aceitando apenas contas ativas. Credenciais válidas geram JWT assinado, com identificação do usuário e expiração de até 15 minutos. O servidor deve validar assinatura e validade do token. O front guarda o token somente em memória e o remove no logout; expiração ou recarga exige novo login. Não haverá refresh token ou tabela de sessões. O logout não invalida uma cópia do token, que permanece utilizável até expirar. Credenciais incorretas devem receber mensagem genérica, sem revelar se a conta existe.

[ ] SEC04 — Autorização e proteção das rotas: Implementar verificações reutilizáveis no FastAPI para autenticação, conta ativa e papel de Bibliotecário. Aplicá-las em todas as rotas restritas, independentemente dos controles do front. Consultas do Leitor devem filtrar registros pela identidade obtida do token, inclusive em listas e pesquisas. Operações de gestão exigem Bibliotecário; mudanças de papel ficam em operação específica, separada da edição cadastral. Retornar 401 para autenticação inválida e 403 para falta de permissão. Penalidade por atraso impede empréstimos, sem bloquear login ou consulta.

[ ] SEC05 — Testes e documentação: Verificar armazenamento por hash, login válido, rejeição de credenciais incorretas e tokens adulterados ou expirados, bloqueio de contas inativas e acesso sem autenticação. Confirmar que um leitor não consulta registros de outro, não executa gestão e não altera o próprio papel pelo corpo da requisição. Confirmar também as operações permitidas ao Bibliotecário e o registro básico de auditoria.